Wednesday
27/8/26

* Case study - 1

- Bright Mart is a medium sized online shopping company. Customers use ~~this~~ it's website & mobile app to purchase.

→ The company stores:

1. Customer names
2. Email addresses
3. Phone no.s
4. Delivery addresses
5. Passwords
6. Order information
7. Payment related information

- Bright Mart has around 100 employees.
- The company recently hired several new employees. To make things easier, the IT department gave employees to different internal systems.

→ Company has the following security weakness:

- Some employees use simple passwords such as Brightmart.
- Many employees use the same passwords for multiple systems.
- Software updates are sometimes delayed.
- The company doesn't regularly employee cybersecurity training.
- There is no multi-factor authentication for some important accounts.
- Employees can access sensitive info that they don't necessarily need for their jobs.
- Backups are performed only once a ~~week~~ month.

→ The incidents:

- One Monday morning, an employee named Rahul receives an email.
- Subject:- Urgent - Your account will be suspended.
- The email appears to come from the company's IT department
- It says:
  - Your company account will be suspended today. Click the below link & verify your password immediately.
- Rahul clicks the link
- The page looks almost identical to the company's login page
- He enters his username & password
- Rahul doesn't realize that the website is controlled by an attacker.
- Now attacker has Rahul's credentials.

Stage - 1 → Unauthorised Access

- Attacker uses Rahul's credentials to access Bright Mart's internal system.
- Because Rahul uses the same password for ~~author~~ another system. The attacker is able to access that system too.
- Attacker discovers Rahul has access to customer data.
- Attacker downloads large amount of customer data.

Q. What cybersecurity problem has occured?

Stage 2 → Malware Attack

- The attacker sends another email to Rahul containing a malicious attachment.
- Malware is installed on his computer.

- Malware begins communicating with the attackees system.
- Attacker now begins/attempts to move from Rahul's computer to other systems with Bright Mart's network.

Q Which vulnerability allowed the attacker to move forward with the organization?

Stage-3 → Ransomware

- Two days later, employees arrive at work & discover that they cannot access important files.
- A message appears on their computers:
  "Your files have been encrypted. Pay the ransom to recover them."
- The company's customer database & several important business files are encrypted.
- Unfortunately, the company's most recent backup is almost a month old.
- Bright Mart's website stops working.
- Customers cannot place orders
- Customer support ~~the~~ team cannot access customer records.

Stage -4 → Business Impact

- Bright Mart now faces several problems:

→ Financial Impact
- The company loses sales because its website is unavailable

→ Data Impact
- Customer information may have been stolen.

→ Operational Impact
- Employees cannot access important systems.

→ Reputational Impact
- Customers lose confidence in the company

→ Legal / Compliance Impact
- Company may face regulatory or legal consequences depending on what information was exposed & which laws apply.

Ans 1] (i) Phishing
(ii) Credential theft
(iii) Unauthorized access
(iv) Data breach.

Ans 2] Vulnerabilities:-
(i) Weak passwords
(ii) Excessive user privileges
(iii) Lack of MFA (Multi-factor Authentication)
(iv) Poor network security
(v) Lack of employee awareness
(vi) Outdated software.

Q3] What threats are present in this case?
Ans 3] (i) Phishing
(ii) Malware
(iii) Ransomware
(iv) Credential Theft
(v) Unauthorized Access
(vi) Data Theft.

Q4] What weaknesses were in BrightMart's security allowed the attack to succeed?

Ans4]

Vulnerability	How it helped the attacker
Weak passwords	Easier to compromise accounts
Password reuse	One stolen password give access to multiple systems
No MFA	Stolen password may be enough to login
Lack of training	Employees falls for phishing
Delayed updates	Vulnerable software may be exploited.
Excessive privileges	Attacker can access more data
Infrequent backups	Difficult to recover after ransomware

Q5] Was confidential information exposed?

Ans5] Yes, customer information was accessed/downloaded by the attacker.

Q6] Was information changed or damaged?

Ans6] Potentially yes, the attacker could modify or encrypt files.

Q7] Were systems available to legitimate users?

Ans7] The website and internal systems become unavailable because of ransomware.

Confidentiality → Affected
Integrity → Affected
Availability → Affected.

Q8] Who is responsible for cybersecurity?

Ans 8] Not only IT department. Every employee who uses the organiz systems has a role in cybersecurity.

Q9] Was phishing the only problem?

Ans 9] Phishing was the initial attack, but weaknesses such as pass reuse, lack of MFA, excessive privileges, poor backups, and insufficient training allowed the attack to become much mor damaging.

Q10] What was the biggest vulnerability?

Ans 10] Poor backup practices were the biggest problem because BrightMast could not quickly recover from ransomware.

Quick Assessment

Q1] What was the initial attack against BrightMast?

Ans] Initially the attacker used phishing which was possible du to vulnerabilities in the website which made it easier to make a replica.

Q2] Incomplete

Q2] Give 3 vulnerabilities that helped the attacker.

Ans] • Employees reused the same passwords.
• Employees reused the same passwords
• MFA was not enabled for some important systems.

Q3] Which 3 security Principles of CIA Triad were affected?

Ans] Confidentiality
Integrity
Availability

Q4] What was the impact of Ransomware on BrightMost?

Ans] Ransomware encrypted important files, stopped the website and prevented employees from accessing internal essential systems.

Q5] Suggest 3 security controls BrightMost should implement

Ans] • MFA for important accounts.
• Regular Cybersecurity training for employees.
• Regular Backups.